

Defend Without Destroying: Typed Safety Constraints for Reinforcement-Learning Cyber Defence Agents in Simulation

Anonymous Author(s)
(double-blind submission)

Abstract

A reinforcement-learning (RL) cyber-defence agent cannot simply maximise cumulative reward when its actions can disconnect production machines, block legitimate traffic, or destroy forensic evidence. Existing autonomous cyber defence (ACD) work either folds such harms into a hand-tuned reward or, more recently, treats them uniformly as Lagrangian budgets that are satisfied only in expectation. We argue that *constraints have types*: downtime and blocked traffic are *budget* constraints, whereas evidence destruction and severing a safety-critical asset are *hard*, irreversible constraints, and the safety mechanism should follow the type. We present SAFEACD-SIM, an open-source discrete-time simulation model of a CAGE-2-like enterprise/OT network that emits security reward and four defender-induced harm channels separately, and a TYPED agent that combines PPO-Lagrangian for budgets with a runtime shield, built only from SOC-observable signals, for hard rules (“image before reimage”, “never isolate the OT controller”). Using a pre-registered protocol with common random numbers, ten seeds, and a held-out attacker, we compare reward-only PPO, reward shaping, PPO-Lagrangian, shielded PPO and TYPED. [TODO: one-sentence headline result from results/eval/summary_train_dist.csv] Simulator, agents and protocol are released for reproduction.

Keywords: autonomous cyber defence, safe reinforcement learning, constrained MDP, shielding, digital forensics, simulation.

1 Introduction

Autonomous cyber defence (ACD) agents trained with deep reinforcement learning in simulated “cyber gyms” such as CybORG [20, 28] can now contain scripted intruders at machine speed [9, 25, 34]. Their training objective, however, is almost always a single scalar reward. Whenever a defensive action is effective *because* it is harmful—quarantining a subnet, severing an industrial controller, or reimaging a host before anyone has imaged it—a reward-maximising agent will learn to use it. The resulting policies look excellent on the security metric and are unacceptable to the security operations centre (SOC) that would have to deploy them.

The community’s first response was reward engineering: penalties for restores or for disrupting simulated users [20]. Recent analyses show that dense, engineered rewards bias agents towards riskier policies [5, 6]. The second response, emerging in 2026, moves operational costs into a constrained MDP (CMDP) [4] and enforces budgets with Lagrangian multipliers [32]. Lagrangian methods, however, guarantee constraint satisfaction only *in expectation and asymptotically* [26, 29]: an acceptable contract for “at most ten server-hours of downtime per incident”, but not for “never destroy the evidence of an intrusion”, which incident-response standards treat as non-negotiable [7, 19, 23].

This paper makes the observation that the harms an ACD agent can cause have different *types*, and that the safety mechanism should be chosen per type. Our contributions are:

1. **A typed safety formulation for ACD.** We separate *budget* constraints (production downtime, blocked legitimate traffic) from *hard* constraints (forensic-evidence destruction, isolation of a safety-critical OT asset), and pair the former with Lagrangian relaxation and the latter with a preemptive shield [3] whose rules use only SOC-observable information. To our knowledge this is the first RL-ACD work to model evidence preservation as an explicit, irreversible constraint.
2. **SAFEACD-SIM, an open simulation model** of a 12-host user/enterprise/operational network (mirroring CAGE-2) with scripted attackers, benign traffic, forensic imaging, and *separate* reward and harm channels, together with its verification and validation (V&V) evidence.
3. **A pre-registered simulation experiment** (5 learning conditions, 3 reference policies, 10 seeds, 3 attackers, common random numbers) that quantifies (RQ1) the harm of reward maximisation and the fragility of reward shaping,

(RQ2) typed versus untyped constraint handling, (RQ3) whether the shield must be present during training, and (RQ4) robustness to a held-out attacker, reporting monitor-relative residual violations honestly.

2 Background and Related Work

RL for autonomous cyber defence. CybORG and its CAGE challenges [20, 28] are the de-facto benchmarks; hierarchical and multi-agent PPO agents dominate them [9]. Surveys [21, 25, 34] identify the gap between simulated performance and deployability, and a 2026 expert workshop distilled environment-design guidelines [33]. Environment extensions add realistic actions such as isolation [31], and cyber-range studies evaluate availability costs of learned responders [24]. Optimal stopping formulations offer an analytic alternative [13].

Rewards, constraints and safety in ACD. Dutta et al. [8] verified RL decisions against SMT-encoded requirements. Bates et al. [5, 6] showed that sparse, goal-aligned rewards yield lower-risk policies than dense penalties. Closest to us, ACD³-GAT [32] formulates multi-agent ACD as a CMDP with budgets on mean time to recover, false-positive responses and firewall change disruption, enforced by Lagrangian control and counterfactual screening; all of its constraints are budgets. Hsain and Almuhammadi [15] use shield synthesis for *design-time* defensibility analysis rather than runtime enforcement, and Jamshidi et al. [17] combine PPO with action masking under control-plane safety constraints in SDN-IoT. None of these models forensic evidence, and none assigns mechanisms by constraint type.

Safe RL. A CMDP [4] adds cost signals c_k and thresholds d_k to an MDP and seeks $\max_{\pi} J_r(\pi)$ s.t. $J_{c_k}(\pi) \leq d_k$. Trust-region [1] and Lagrangian [26, 30] methods solve it in expectation; Lagrangian multipliers are known to overshoot and oscillate [29]. Shielding [3] instead removes unsafe actions before (preemptive) or after (post-posed) the agent chooses, giving per-step guarantees relative to the shield’s model; invalid-action masking keeps policy gradients well defined [16]. Irreversible actions are a recognised hazard [11]. See [10, 12] for surveys.

Forensic readiness. NIST SP 800-86 and SP 800-61r3 require evidence to be preserved during containment and eradication [19, 23]; RFC 3227 orders artefacts by volatility [7]. The operational rule of thumb is “image before you reimage”: reimaging restores service but irreversibly erases the artefacts needed for attribution, scoping and legal action.

3 Typed Safety Constraints

We model the defender’s problem as a partially observable CMDP with security reward r and four harm costs $c_1 \dots c_4$, each counting only *defender-induced* harm:

- c_{prod} – criticality-weighted host-steps offline (isolated or being reimaged);
- c_{traf} – weight of active legitimate flows that could not be served;
- c_{evid} – reimages of a compromised host whose current incident was never imaged;
- c_{crit} – steps in which the safety-critical OT controller is isolated.

We partition constraints into a *budget* set $\mathcal{B} = \{\text{prod}, \text{traf}\}$, $\mathbb{E}_{\pi}[\sum_t c_k] \leq d_k$, and a *hard* set $\mathcal{H} = \{\text{evid}, \text{crit}\}$ that must hold on every trajectory, $\Pr_{\pi}[\sum_t c_k > 0] = 0$.

Mechanism per type. TYPED solves the budget part by Lagrangian relaxation,

$$\max_{\pi} \min_{\lambda \geq 0} J_r(\pi) - \sum_{k \in \mathcal{B}} \lambda_k (J_{c_k}(\pi) - d_k), \quad (1)$$

using PPO [27] on the normalised combined advantage $(A_r - \sum_k \lambda_k A_{c_k}) / (1 + \sum_k \lambda_k)$ and projected Adam ascent on λ (as in OmniSafe [18]), and enforces the hard part with a preemptive shield that masks unsafe actions before sampling:

H1 *Image before reimage:* `Restore( $h$ )` is allowed only if a forensic image of h exists that post-dates the host’s open SOC ticket and its last reimage.

H2 *Never sever the OT controller:* `Isolate(OpServer)` is never allowed.

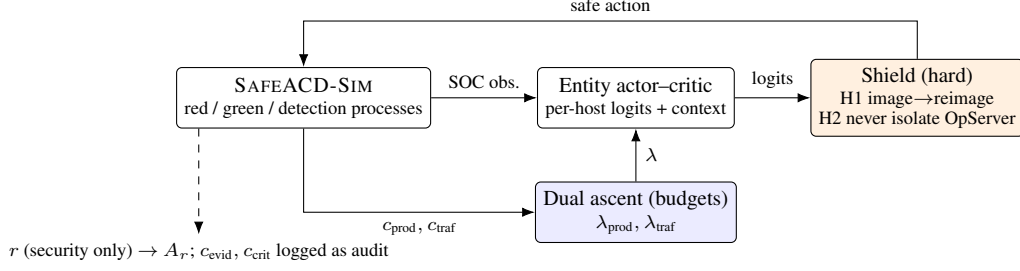


Figure 1: TYPED agent in the loop. Budget harms are priced by Lagrange multipliers; hard harms are prevented by a preemptive shield that reads only SOC-observable state. All four harm channels are logged for every method.

Monitor-relative guarantees. The shield reads only what a SOC has—tickets and image timestamps—never the simulator’s ground truth. H2 is therefore enforced exactly, whereas H1 holds *relative to the monitor*: a compromise that begins after an image and is never detected can still lose artefacts on reimage. We measure this residual rather than claim zero violations by construction.

4 The SAFEACD-SIM Simulation Model

Structure. SAFEACD-SIM is a discrete-time stochastic simulation (100 steps per episode) of 12 hosts in three subnets mirroring CAGE-2: five user workstations, three enterprise servers (Ent0–Ent2) and an operational subnet with the safety-critical OpServer and three OT hosts. Two zone links (user→enterprise, enterprise→operational) can be blocked. Each step the blue agent acts, the red agent acts, benign traffic is sampled, alerts are generated, and reward and costs are emitted (Table 1).

Red agents. Red progresses along an attack graph: an exploit within a zone needs a user-level foothold, crossing a zone needs a privileged one; escalation turns user into privileged access; a privileged foothold on the OpServer allows a mission *impact*. **B-line** heads straight for the OpServer; **Meander** escalates everywhere and expands subnet by subnet; the held-out **Stealthy** attacker is B-line with 30% dwell and 60% lower detection probability. The initial foothold is a random, undetected user host, and an attacker left without a usable foothold re-phishes with probability 0.1.

Benign traffic and evidence. Fifteen weighted business flows (web, file, authentication, historian, control loop) are active with fixed probabilities; a flow is served only if both endpoints are online and the zone link is open. Evidence is *incident-scoped*: the first compromise of a clean host opens an incident; a forensic image taken afterwards preserves it until the host is reimaged.

Defender interface. 77 discrete actions: **Sleep**; per-host **Analyse**, **Forensics** (image), **Remove** (evicts user-level access only), **Restore** (reimage, host offline for two steps), **Isolate**, **Reconnect**; and **Block/Unblock** per zone link. The 87-dimensional observation contains, per host, the SOC ticket severity, the alert raised this step, isolation and reimagining flags, and whether a valid image exists, plus link states and time.

Verification and validation. Twenty automated tests verify determinism under seeding, the cost semantics (image-then-reimage costs no evidence; reimage-without-image costs one; the critical rule; blocked-link traffic loss) and the shield invariants. For operational validation we ran four reference policies on the evaluation seeds (Table 2). The ordering matches expert expectation, and the last row exposes the paper’s motivating problem: the policy with the best *security* return against B-line is the most harmful one. Pilot runs also revealed two modelling artefacts that we fixed before the main experiment and report as V&V lessons: (i) a fixed initial foothold (the CAGE-2 convention) let every learner quarantine one workstation forever and freeze the attacker; (ii) alert-scoped evidence created a dead-lock in which an attacker acting on a host invalidated every new image.

Table 1: Main SAFEACD-SIM parameters (defaults in `safeacd/env.py`).

Parameter	Value
Horizon / restore downtime	100 steps / 2 steps
$P(\text{exploit}), P(\text{escalate})$	0.75, 0.80
$P(\text{detect exploit / escalate / impact})$	0.85 / 0.70 / 1.0 (Stealthy: $\times 0.4$)
$P(\text{false alert per host-step}), P(\text{re-phish})$	0.01, 0.1
Security reward	$-\sum_h v_h (0.5 [\text{user}] + 1 [\text{priv}]) - 10 [\text{impact}]; v = 0.1 \text{ users/OT hosts, 1 servers}$
Downtime weights	users 0.1, servers/OT hosts 1, OpServer 2
Budgets d (prod, traf, evid, crit)	10, 50, 0, 0 per episode

Table 2: Operational validation with reference policies (100 CRN episodes per attacker; per-episode means). R: security return; prod/traf: downtime and blocked-traffic cost. No reference policy destroyed evidence; the reward hacker isolates the OpServer in every step (100 critical violations).

Policy	B-line			Meander		
	R	prod	traf	R	prod	traf
No defence	-1172.7	0.0	0.0	-1131.0	0.0	0.0
Random	-528.8	328.8	1019.4	-387.1	328.8	1019.4
SOC playbook (image before reimage)	-78.8	12.5	52.4	-13.3	3.2	31.0
“Isolate OpServer + block”	-47.6	200.0	1319.2	-47.6	200.0	1319.2

5 Experimental Design

Conditions. All learning conditions share one PPO implementation and hyper-parameters (8 environments $\times$ 256 steps, 10 epochs, minibatch 256, learning rate $3 \cdot 10^{-4}$, $\gamma = 0.99$, GAE $\lambda = 0.95$, clip 0.2, entropy 0.01, tanh MLPs 256–256, critic with one reward and four cost heads); they differ only in safety handling: **PPO** (security reward only); **Shaped- β** (reward minus $\beta(c_{\text{prod}} + c_{\text{traf}} + 10c_{\text{evid}} + 10c_{\text{crit}})$, $\beta = 1$ in the main grid, $\beta \in \{0.1, 0.3, 3, 10\}$ in a sweep); **Lag** (PPO-Lagrangian on all four channels with $d = (10, 50, 0, 0)$); **Shield** (security reward plus shield); and **TYPED** (Lagrangian on the two budgets plus shield). Invalid-action masking is applied everywhere. The budgets encode “no more collateral harm than the incumbent playbook”: the playbook’s mean downtime and traffic cost under the training distribution are 7.9 and 41.7.

Protocol. Each condition is trained for 10^6 steps on a uniform B-line/Meander mixture with ten seeds (five for the β sweep). Each trained stochastic policy is evaluated for 100 episodes per attacker, including the held-out Stealthy attacker. Evaluation episode i uses the same seed for every policy, and the red, green and detection processes draw from independent random streams, so comparisons use *common random numbers* [22]. For RQ3 we additionally deploy the unshielded policies with the shield attached (“+S”). We report seed-level means with 95% percentile-bootstrap CIs and IQM [2, 14]; pre-registered comparisons use Mann–Whitney U tests on seed means and, against the playbook, Wilcoxon signed-rank tests on CRN-paired episodes, all Holm-corrected. The full protocol is in the artefact (`docs/methodology.md`).

6 Results

[TODO: run scripts/analyze.py]

RQ1: The cost of maximising reward. [TODO: fill from tables/main.tex and figures/shaping.pdf]

RQ2: Typed versus untyped constraints. [TODO: fill; cite tests.csv]

RQ3: Shield during training or only at deployment? [TODO: fill from tables/ablation.tex]

[TODO: pareto figure]

Figure 2: Security return versus normalised collateral harm (log scale) under the training distribution; hollow markers indicate hard-constraint violations.

[TODO: learning curves]

Figure 3: Training dynamics (mean and 10–90% band over seeds). Dashed lines are budgets. The right panel counts hard violations committed *during training* (log scale).

RQ4: Held-out attacker. [TODO: fill from tables/ood.tex]

7 Discussion and Threats to Validity

Implications. [TODO: after results]

Threats. *Internal:* hyper-parameters were shared, not tuned per condition; the β sweep bounds the effect of tuning the shaping baseline. *Construct:* downtime and traffic are proxies, and evidence is modelled as a binary per-incident property, whereas real artefacts are graded by volatility [7]. *External:* one 12-host topology with scripted attackers; our claims concern safety *mechanisms*, not deployment-ready agents; porting the cost channels to CybORG/CAGE-4 is future work. *Conclusion:* ten seeds, CRN pairing, bootstrap CIs and Holm correction; near-zero violation rates are reported with exact binomial upper bounds.

8 Conclusion

[TODO: 3–4 sentences after results]

Artefact availability. Simulator, agents, configuration, raw evaluation records and analysis scripts: [TODO: anonymised repository / Zenodo DOI].

References

- [1] Joshua Achiam, David Held, Aviv Tamar, and Pieter Abbeel. Constrained policy optimization. In *Proceedings of the 34th International Conference on Machine Learning (ICML)*, volume 70 of *PMLR*, pages 22–31, 2017.
- [2] Rishabh Agarwal, Max Schwarzer, Pablo Samuel Castro, Aaron Courville, and Marc G. Bellemare. Deep reinforcement learning at the edge of the statistical precipice. In *Advances in Neural Information Processing Systems (NeurIPS)*, volume 34, 2021.
- [3] Mohammed Alshiekh, Roderick Bloem, Rüdiger Ehlers, Bettina Könighofer, Scott Niekum, and Ufuk Topcu. Safe reinforcement learning via shielding. In *Proceedings of the AAAI Conference on Artificial Intelligence*, volume 32, 2018.
- [4] Eitan Altman. *Constrained Markov Decision Processes*. Chapman and Hall/CRC, 1999.
- [5] Elizabeth Bates, Chris Hicks, and Vasilios Mavroudis. Less is more? Rewards in RL for cyber defence. *arXiv preprint arXiv:2503.03245*, 2025.
- [6] Elizabeth Bates, Chris Hicks, and Vasilios Mavroudis. Beyond rewards in reinforcement learning for cyber defence. *arXiv preprint arXiv:2602.04809*, 2026.
- [7] Dominique Brezinski and Tom Killalea. Guidelines for evidence collection and archiving. RFC 3227, Internet Engineering Task Force, 2002.

- [8] Ashutosh Dutta, Ehab Al-Shaer, and Samrat Chatterjee. Constraints satisfiability driven reinforcement learning for autonomous cyber defense. In *Proceedings of the 1st International Conference on Autonomous Intelligent Cyber-Defence Agents (AICA)*, 2021. arXiv:2104.08994.
- [9] Myles Foley, Chris Hicks, Kate Highnam, and Vasilios Mavroudis. Autonomous network defence using reinforcement learning. In *Proceedings of the 2022 ACM Asia Conference on Computer and Communications Security (ASIA CCS)*, 2022.
- [10] Javier García and Fernando Fernández. A comprehensive survey on safe reinforcement learning. *Journal of Machine Learning Research*, 16(42):1437–1480, 2015.
- [11] Nathan Grinsztajn, Johan Ferret, Olivier Pietquin, Philippe Preux, and Matthieu Geist. There is no turning back: A self-supervised approach for reversibility-aware reinforcement learning. In *Advances in Neural Information Processing Systems (NeurIPS)*, volume 34, 2021.
- [12] Shangding Gu, Long Yang, Yali Du, Guang Chen, Florian Walter, Jun Wang, and Alois Knoll. A review of safe reinforcement learning: Methods, theories and applications. *IEEE Transactions on Pattern Analysis and Machine Intelligence*, 46(12), 2024.
- [13] Kim Hammar and Rolf Stadler. Intrusion prevention through optimal stopping. *IEEE Transactions on Network and Service Management*, 19(3), 2022.
- [14] Peter Henderson, Riashat Islam, Philip Bachman, Joelle Pineau, Doina Precup, and David Meger. Deep reinforcement learning that matters. In *Proceedings of the AAAI Conference on Artificial Intelligence*, volume 32, 2018.
- [15] Achraf Hsain and Sultan Almuhammadi. Shielded analysis: Certification and characterization of defensibility in systems under adversarial interaction. *arXiv preprint arXiv:2606.13621*, 2026.
- [16] Shengyi Huang and Santiago Ontañón. A closer look at invalid action masking in policy gradient algorithms. In *Proceedings of the International FLAIRS Conference*, volume 35, 2022.
- [17] Saeid Jamshidi, Negar Shahabi, Foutse Khomh, Carol Fung, and Mohammad Hamdaqa. Multi-agent LLM governance for safe two-timescale reinforcement learning in SDN-IoT defense. *arXiv preprint arXiv:2604.01127*, 2026.
- [18] Jiaming Ji, Jiayi Zhou, Borong Zhang, Juntao Dai, Xuehai Pan, Ruiyang Sun, Weidong Huang, Yiran Geng, Mickel Liu, and Yaodong Yang. OmniSafe: An infrastructure for accelerating safe reinforcement learning research. *Journal of Machine Learning Research*, 25(285):1–6, 2024.
- [19] Karen Kent, Suzanne Chevalier, Tim Grance, and Hung Dang. Guide to integrating forensic techniques into incident response. Technical Report SP 800-86, National Institute of Standards and Technology, 2006.
- [20] Mitchell Kiely et al. CAGE challenge 4: A scalable multi-agent reinforcement learning gym for autonomous cyber defence. *AI Magazine*, 46(3), 2025. doi: 10.1002/aaai.70021. TODO-VERIFY full author list.
- [21] Alexander Kott, editor. *Autonomous Intelligent Cyber Defense Agent (AICA): A Comprehensive Guide*. Springer, 2023.
- [22] Averill M. Law. *Simulation Modeling and Analysis*. McGraw-Hill, 5th edition, 2015.
- [23] National Institute of Standards and Technology. Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile. Technical Report SP 800-61 Rev. 3, NIST, 2025. TODO-VERIFY author list.
- [24] Jakob Nyberg, Teodor Sommestad, Andrei Buhaiu, Joakim Loxdal, Pontus Johnson, and Mathias Ekstedt. A cyber range evaluation of autonomous network incident response agents. *arXiv preprint arXiv:2609.16541*, 2026.

- [25] Gregory Palmer, Chris Parry, Daniel J. B. Harrold, and Chris Willis. Deep reinforcement learning for autonomous cyber operations: A survey. *arXiv preprint arXiv:2310.07745*, 2023.
- [26] Alex Ray, Joshua Achiam, and Dario Amodei. Benchmarking safe exploration in deep reinforcement learning. Technical report, OpenAI, 2019.
- [27] John Schulman, Filip Wolski, Prafulla Dhariwal, Alec Radford, and Oleg Klimov. Proximal policy optimization algorithms. *arXiv preprint arXiv:1707.06347*, 2017.
- [28] Maxwell Standen, Martin Lucas, David Bowman, Toby J. Richer, Junae Kim, and Damian Marriott. CybORG: A gym for the development of autonomous cyber agents. In *IJCAI-21 1st International Workshop on Adaptive Cyber Defense*, 2021. *arXiv:2108.09118*.
- [29] Adam Stooke, Joshua Achiam, and Pieter Abbeel. Responsive safety in reinforcement learning by PID Lagrangian methods. In *Proceedings of the 37th International Conference on Machine Learning (ICML)*, volume 119 of *PMLR*, pages 9133–9143, 2020.
- [30] Chen Tessler, Daniel J. Mankowitz, and Shie Mannor. Reward constrained policy optimization. In *International Conference on Learning Representations (ICLR)*, 2019.
- [31] Konur Tholl, François Rivest, Mariam El Mezouar, Adrian Taylor, and Ranwa Al Mallah. Towards production-worthy simulation for autonomous cyber operations. *arXiv preprint arXiv:2508.19278*, 2025.
- [32] TODO-VERIFY authors. Safety-contract graph multi-agent reinforcement learning for autonomous network security response. *arXiv preprint arXiv:2606.13832*, 2026.
- [33] TODO-VERIFY authors. Building better environments for autonomous cyber defence. *arXiv preprint arXiv:2604.08805*, 2026.
- [34] Sanyam Vyas, John Hannay, Andrew Bolton, and Pete Burnap. Automated cyber defence: A review. *arXiv preprint arXiv:2303.04926*, 2023.